

Orion Health Services Ransomware attack:

Summary: On the morning of September 14, 2026 Orion Health Services suffered a ransomware attack through a targeted phishing email. This breach resulted in compromised patient and employee data and a major system outage.

Incident Timeline:

- Phase 1: Phishing email sent to Finance department
- Phase 2: Malicious attachment executed, leading to initial access
- Phase 3: Attacker used Mimikatz to harvest credentials and gain privileges
- Phase 4: IT Department detected unusual outbound traffic
- Phase 5: Ransom note deployed and backup server partially compromised

Data Impact:

- Employee payroll records and Patient appointment schedules (HIPAA) compromised

Operational Impact:

- File server, HR, and finance systems offline

Business Continuity Impact:

- Backups are partially compromised due to partial encryption, making recovery significantly harder.

Indicators of Compromise (IOC)

- Suspicious login from overseas IP.
- Execution of Mimikatz
- .orionlock file extension on compromised data

Root Cause:

- Human Gap: Lack of sufficient security and phishing awareness training as phishing email was successful.
- Technical Gap: Insufficient email gateway filtering, excessive user privileges, or a lack of fixed, air-gapped backups

Remediation:

- Instantly pulling the network cables on all affected servers to isolate the threat
- Force a global password reset for all employees and revoke all active session tokens since the attackers used Mimikatz to harvest credentials.
- Patching the vulnerabilities, and restoring systems using the clean, unencrypted portions of the backups and wiping the infected servers.

Future Prevention and Recommendations:

- Implement MANDATORY phishing-resistant MFA
- Setting up MANDATORY employee phishing awareness training
- Setting up strict email gateway filters to catch malicious excel macros
- Establish true air-gapped, immutable backups